Backlog Sprints 3 & 4

Sprint 3 — Gouvernance IA : Audit trail, PII Masking & Token Budget

Livrable	Détail	Effort
Table `llm_audit_log`	Migration Flyway : id, tenant_id, user_email, session_id, intent, model_used, prompt_hash (SHA-256), tokens_input/output, latency_ms, fallback_used, guard_blocked, created_at — index sur (tenant_id, created_at)	1 j/h
Instrumentation `LLMAIClient`	Log de chaque appel LLM dans `llm_audit_log` après réponse (modèle utilisé, tokens, latence, bascule fallback)	2 j/h
`PiiMasker.java`	Masquage avant envoi LLM : emails → `[EMAIL]`, IBAN/BIC → `[IBAN]`, noms propres → `[NOM]`, téléphones → `[TEL]`, IP → `[IP]` ; seul le prompt masqué est loggué	2,5 j/h
`TenantTokenBudgetService`	Budget mensuel par tenant (table `tenant_token_budget`), alerte admin à 80 %, blocage HTTP 429 à 100 %, reset automatique le 1er du mois (défaut 500 000 tokens/mois)	2 j/h
Dashboard platform_admin	Graphes consommation LLM (tokens, coût estimé, latence p95) par tenant et par mois	1 j/h
Correctif dette technique #8	Route Kong `/invoices/*` sans plugin jwt/rate-limiting/cors, contrairement à la route ai-core — alignement sur le même standard de sécurité (bloquant Go/No-Go Octobre)	1,3 j/h
Correctif dette technique #6 (résiduel)	Finalisation de la résilience Kafka `platform.notifications` : passage en ack manuel sur les listeners (retry + DLT déjà livrés, branche `sprint3`)	0,5 j/h

Sous-total Sprint 3 : 10,3 jours/homme

Sprint 4 — Sécurité avancée, RGPD & Versioning des modèles

Livrable	Détail	Effort
Droit d'accès & portabilité	`GET /privacy/export` → ZIP téléchargeable en < 30 s (notes de frais, CRA, profil)	2 j/h
Droit à l'oubli	`DELETE /privacy/erase` → anonymisation vérifiable en base (factures légales conservées, non supprimées)	2 j/h
Opposition au profiling	Flag `opt_out_llm_training` sur le tenant, endpoint de gestion	0,5 j/h
`llm_model_registry`	Table (model_id, provider, version, deployed_at, deprecated_at, replacement) + rollback automatique si un modèle génère plus de 5 % d'erreurs JSON en 10 min	2 j/h
Runbook incident LLM	`docs/RUNBOOK-LLM.md` : détection → confinement → rollback → post-mortem, alerte si fallback Groq→OpenAI dure plus de 15 min	1 j/h
Supply chain (OWASP LLM05)	OWASP Dependency Check intégré en CI, objectif 0 CVE critique	1 j/h
Avertissement IA (OWASP LLM09)	Message « données extraites par IA — à vérifier » visible sur les notes de frais issues de l'OCR	0,8 j/h
Correctif dette technique #1 (Critique)	Résolution des secrets K8s en clair : placeholders `$OPENAI_API_KEY`, `$AI_CORE_ADMIN_KEY`, `$KEYCLOAK_ADMIN_PASSWORD` non résolus dans `ai-service/deploy/k8s/secret.yaml` — bloquant Go/No-Go Octobre	1 j/h

Sous-total Sprint 4 : 10,3 jours/homme

Conformité au devis

Sprint	Effort	Montant (devis DV-2026-08-005)
Sprint 3	10,3 j/h	6 180 € HT
Sprint 4	10,3 j/h	6 180 € HT